

AI Governance: Policy to Practice

How to turn rules like the EU AI Act into things we actually do every day.

Farah Abdou

AI Researcher & Lead Machine Learning Engineer ([Farah M. Abdou | LinkedIn](#))

What we will cover

- | | | |
|-----------|---|--|
| 01 | The gap | Why good rules stop before they reach our daily work |
| 02 | The rules today | EU AI Act risk levels, dates, and how NIST and ISO fit |
| 03 | Example 1: How staff use LLMs | Turning a usage policy into real behaviour |
| 04 | Example 2: Rules inside the pipeline | Governance-as-code, model cards, audit trails |
| 05 | Example 3: One system, start to finish | Taking a high-risk model through the EU AI Act |
| 06 | Lessons and next steps | What you can start on Monday |

THE PROBLEM

A rule no one can follow is not governance. It is just paperwork.

Written for lawyers

Words like "fairness" and "human oversight" are correct, but an engineer cannot act on them at a keyboard.

Far from the real work

The policy sits in a PDF on the intranet. It is not in the code, the pipeline, or the pull request.

Checked once, then forgotten

A risk check signed at launch is out of date the moment the model is retrained or reused.

My main point: treat the rules like code. Keep them in version control, test them, and check them where the work actually happens.

The EU AI Act sorts AI by risk level

Unacceptable

Banned

Social scoring, systems that manipulate people, building face databases by scraping the internet/CCTV, and live face recognition in public.

High risk

Strict rules before launch

Credit scoring, hiring, biometrics, key infrastructure, education, medical devices. Needs risk checks, good data, logging, and human oversight.

Limited risk

Just be transparent

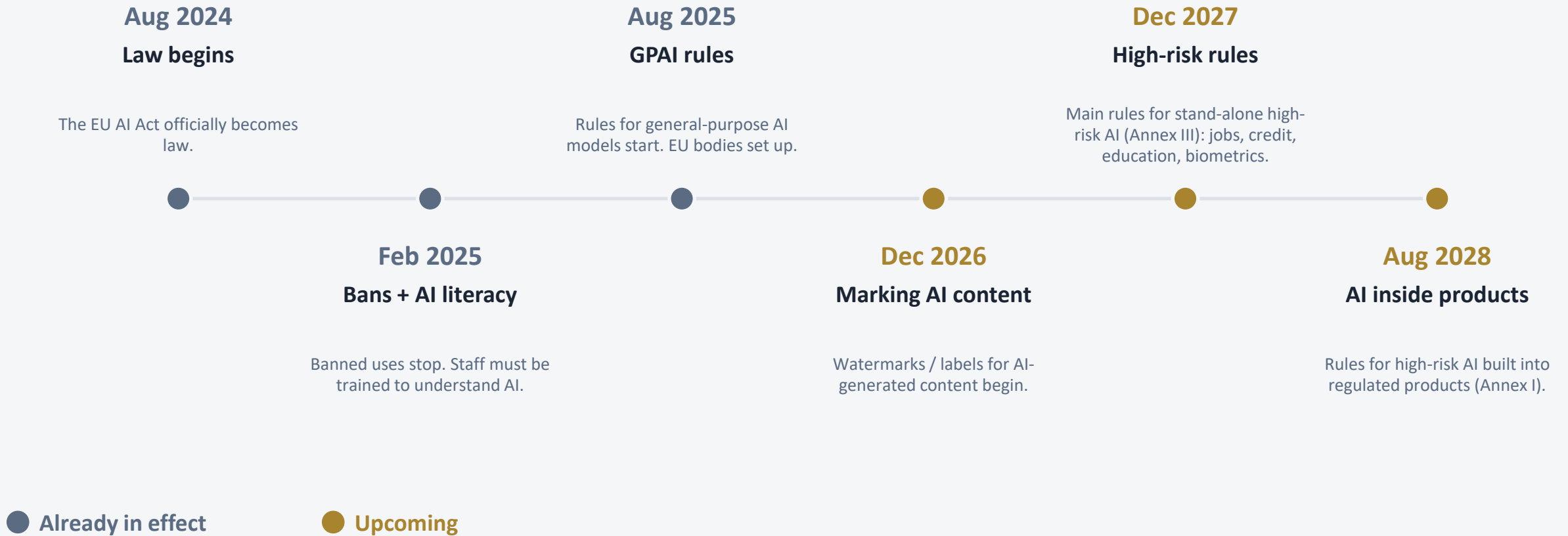
Chatbots and AI-made content. You must tell people they are dealing with AI, and label AI-made images and video.

Minimal risk

No rules

Spam filters, recommendations, and most everyday AI. Good practice is encouraged, but nothing is required.

The dates come in stages, and the clock is running



The law says what; the standards say how

EU AI Act

The law (you must)

- Legally binding in the EU
- Rules depend on risk level
- Fines: up to €35M / 7% of revenue (banned uses)
... or €15M / 3% (high-risk breaches)
- Tells you WHAT you must do

NIST AI RMF

A guide from the US (optional)

- Four steps: Govern, Map, Measure, Manage
- A special guide for generative AI
- Focused on managing risk
- Gives everyone shared words
- Free to use, widely adopted

ISO/IEC 42001

A standard you can certify

- Sets up an AI management system
- Plan, Do, Check, Act - then repeat
- Can be audited and certified
- Tells you HOW to run it day to day

PRACTICE

01

How Staff Use LLMs

Turning an LLM usage policy into behaviour people actually follow.

What a good LLM usage policy contains

Who and what it covers

Name the people (staff, contractors, vendors) and name the tools (ChatGPT, Copilot, Gemini) in plain words.

Approved vs banned tools

A short list of allowed tools. Anything not listed is banned by default; IT blocks it.

Data rules

No confidential, personal, or company data into public LLMs. Reuse the data rules you have.

Human oversight

AI can help, but a person makes the final call on any real decision.

Training and sign-off

Everyone gets AI training and signs the policy. Also an EU AI Act duty since Feb 2025.

Reporting and consequences

One named owner, a place to report problems, and clear consequences if the rules are broken.

From a written rule to something real

POLICY SAYS

"Protect confidential data."

"Use only approved tools."

"Keep a human in the loop."

IN PRACTICE

A company LLM account that keeps no data, plus DLP rules that catch secrets before they leave the network.

Login-gated allow-list. IT blocks other AI sites. One click to request a new tool.

A real sign-off step in the workflow for any AI-assisted decision about a customer or employee.

The idea: every rule needs a control that makes the wrong action hard and the right action easy.

PRACTICE

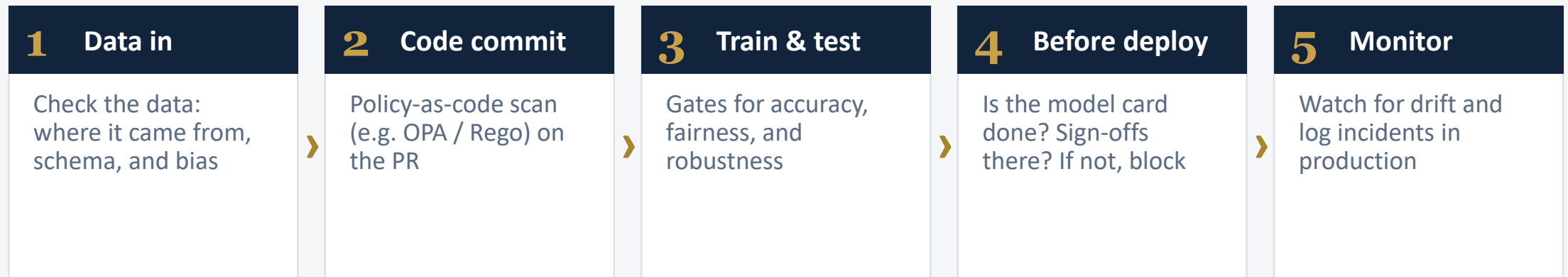
02

Rules Inside the Pipeline

Governance-as-code: from a PDF policy to an automatic check in CI/CD.

Governance-as-code: rules that run by themselves

Write the rule as code, keep it in version control next to the model, and let a policy engine check it automatically at every stage.



Article 11 and Annex IV ask for up-to-date technical documentation and traceability. A pipeline like this produces that on its own, as you work.

The model card: a label that ships with the model

WHAT IT CONTAINS

- What it is for, and what it must not be used for
- Model type, version, and change log
- Training data: where it came from, rights, quality
- How well it works; overall and per group of people
- Known limits, bias, and risk that is left over
- Owner, approval status, and when to re-check it

WHY IT MATTERS

Proof for an audit

The record an auditor wants to see. It meets the AI Act documentation rules directly.

It stays current

It is versioned with the model and rebuilt on every retrain. An old card is worse than none.

A shared language

Legal and business can understand the risk without an ML background.

Traceability: if it is not logged, it did not happen

Who

The person behind every model change, approval, and deploy

What

The exact code, data, and config behind each released model

When

Timestamps that cannot be changed, at every step

Why

The linked ticket, risk check, and reason for sign-off

How we get this in practice: git-tracked config · data and model versioning · CI/CD logs · a central model registry · append-only logs you cannot edit.

The AI Act asks high-risk systems to keep these records (Article 12). It is also the difference between a one-week audit and a six-month scramble.

PRACTICE

03

One System, Start to Finish

A worked example: one high-risk model, from risk check to CE marking.

Our example: an AI credit-scoring model

System: A model that scores loan applicants to support credit decisions for a financial institution operating in the EU.

Why is it high-risk?

Annex III names credit scoring directly. It can stop someone from getting an essential service.

Can it skip the rules?

No. The narrow-task exemptions do not apply, because it profiles people and shapes the decision.

Why this example?

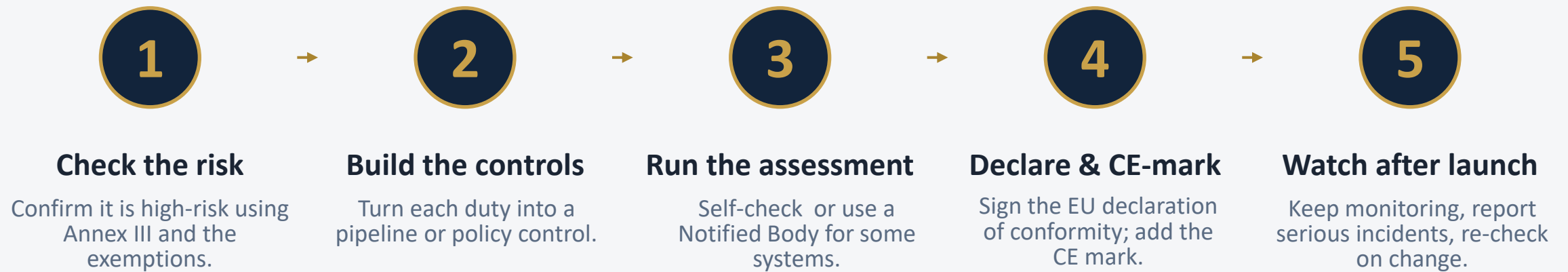
It is everyday work in finance, and a textbook case of high-risk AI.

Each legal duty becomes one real control

What the law asks for	What we actually do	From
Risk management	A written risk register, reviewed every release	Ex 2
Data quality	Bias and source checks at data-in; representative data	Ex 2
Technical documentation	Auto-built model card (Art. 11 / Annex IV)	Ex 2
Record-keeping / logging	A log that cannot be edited, across the model life (Art. 12)	Ex 2
Be clear with users	Plain instructions for use and known limits	Ex 1
Human oversight	A loan officer reviews and can override every score	Ex 1
Accuracy and robustness	Test gates plus drift monitoring against set thresholds	Ex 2

Almost every legal duty is met by something Example 2 (the pipeline) or Example 1 (the usage policy) already produces. Build those two well, and most of this is done.

The path to launch: five steps



Remember the dates: stand-alone high-risk rules now apply from 2 Dec 2027 (Digital Omnibus), product-embedded AI from Aug 2028. So this workflow needs to exist now.

LESSONS

Five lessons that work under any framework

- | | | |
|----------|--|--|
| 1 | Start early (shift left) | Build governance in at design and commit time, not on launch day. The earlier, the cheaper. |
| 2 | Make the right path the easy path | Give people defaults, templates, and one-click flows, so the compliant choice is the easy one. |
| 3 | Let the work create the paperwork | Build model cards and audit logs from the pipeline. Never as a separate, manual scramble. |
| 4 | Always have a human owner | A named owner for every model, and a person who can review and override any big decision. |
| 5 | Keep checking, not just once | Re-check on every retrain or reuse. A check signed once is already out of date. |

LESSONS

Common mistakes and how to avoid them

✗ A policy nobody follows

A nice PDF that no one reads or enforces.

→ Tie each rule to a control with an owner.

✗ Trying to do everything at once

Trying to govern every system on day one.

→ Start with your highest-risk model, then grow.

✗ Copy-paste templates

A generic policy that ignores your real risks.

→ Fit it to your tools, data, and use cases.

✗ Set it and forget it

Governance frozen on launch day.

→ Re-check on every retrain and reuse.

✗ Legal and engineers apart

Compliance and ML teams never talk.

→ Share one model registry and one board.

✗ Buying tools, skipping people

A new platform but no training.

→ Invest in training and clear ownership.

TAKEAWAYS

1

List your AI

Write down every model and LLM tool in use, including the shadow AI nobody admits to.

2

Sort it by risk

Tag each one against the four levels. Find your high-risk systems first.

3

Ship one LLM policy

A short allow-list, one data rule, and a sign-off beat a long document.

4

Add one pipeline gate

Auto-build a model card, or block deploy without sign-off. Prove it, then scale.

REFERENCES

Sources & further reading

1. [European Commission — Regulatory framework for AI](#)
2. [EU Artificial Intelligence Act — Article 6 \(high-risk classification\)](#)
3. [EU AI Act — Implementation Timeline](#)
4. [NIST — AI Risk Management Framework](#)
5. [ModelOp — NIST vs ISO 42001 framework comparison](#)
6. [WilmerHale — What are high-risk AI systems under the EU AI Act](#)
7. [Achieving EU AI Act Compliance by Integrating Governance-as-Code into MLOps](#)
8. [Frontiers in AI — Audit-as-code: policy-as-code for continuous AI assurance](#)
9. [IAPP — 5 things to know about AI model cards](#)
10. [Credo AI — Model Card glossary](#)
11. [Corporate Compliance Insights — Planning your AI policy](#)
12. [Trilateral Research — EU AI Act timeline & risk tiers](#)

From policy to practice

**Governance is not a document.
It is something you build in.**

Thank you. Questions welcome.

Farah Abdou